aLinha

Inês Lourenço 125895, Martim Gil 124833
Iris Lucas 125348, Tomas Xavier 125438
Afonso Santos 125834

Cadeira: Projeto de Engenharia Informática

Índice

1. Introdução 3
    1.1 Contexto 3
    1.2 Objetivos 3
    1.3 Enquadramento Legal 3
    2.3 Atores 6
        2.3.1 Responsável designado 6
        2.3.2 Analista 7
        2.3.3 Consultor 7
        2.3.4 Atores secundários 7
        2.3.5 Entidades externas que não são atores 8
    2.4 Personas 8
    2.5 Cenários 10
        Cenário #1: Adesão à plataforma 10
        Cenário #2: Validação dos resultados 10
        Cenário #3: Aprovação de uma política 10
        Cenário #4: Submissão de evidências 11
        Cenário #5: Resposta a um incidente 11
        Cenário #6: Acompanhamento da carteira de clientes 11
    2.6 User Stories 12
        Consultor 12
        Responsável designado 13
        Analista 16
        Todos os utilizadores 17
3. Requisitos 18
    3.1 Requisitos Funcionais 18
        3.1.1 Gestão da Organização 18
        3.1.2 Avaliação de Maturidade e Conformidade 18
        3.1.3 Remediação e Evidências 19
        3.1.4 CISO Assistido por IA 19
        3.1.5 Monitorização e Apoio a Incidentes 20
        3.1.6 Gestão de Ativos e Riscos 20
        3.1.7 Evidências e Rastreabilidade 20
    3.2 Requisitos Não Funcionais 21
        3.2.1 Disponibilidade e Fiabilidade 21
        3.2.2 Multi-tenancy e Auditabilidade 21
        3.2.3 Segurança 21
        3.2.4 Inteligência Artificial 21
        3.2.5 Desempenho, Extensibilidade e Operação 22
4. Notebook da Arquitetura 23
        4.1 Arquitetura 23
        4.2 Escolha das tecnologias 24

1. Introdução

1.1 Contexto

Nos últimos anos, a União Europeia aprovou um conjunto de regras que mudou a forma como as organizações têm de tratar a segurança da informação, os dados pessoais e as tecnologias que usam. As principais são:

- o **Regulamento Geral sobre a Proteção de Dados (RGPD)**, Regulamento (UE) 2016/679;
- a **Diretiva NIS2**, Diretiva (UE) 2022/2555, que alarga as obrigações de cibersegurança a muitos mais setores e entidades;
- o **Regulamento da Inteligência Artificial (AI Act)**, Regulamento (UE) 2024/1689, que define obrigações para quem desenvolve ou utiliza sistemas de IA.

Para as grandes empresas, cumprir estas regras é um desafio. Para as pequenas e médias empresas (PME), que são a grande maioria do tecido empresarial português, é muitas vezes um obstáculo difícil de ultrapassar. A maioria das PME não tem um **CISO** (*Chief Information Security Officer*), ou seja, um responsável de segurança da informação. Também não tem recursos para contratar alguém a tempo inteiro com conhecimentos técnicos e jurídicos nesta área. Mesmo assim, estas empresas estão expostas aos mesmos riscos de ciberataques, às mesmas exigências legais e, em muitos casos, a coimas pesadas se não cumprirem.

1.2 Objetivos

O projeto **aLinha** pode resumir-se numa frase: **ajudar as pequenas e médias empresas a alinharem-se com as leis de cibersegurança e proteção de dados**.

Para isso, propomos uma plataforma de **CISO-as-a-Service**. A ideia é oferecer como serviço a função de responsável de segurança da informação, adaptada à dimensão e ao orçamento de cada PME. Os objetivos do projeto são:

- **Avaliar** o nível de conformidade de cada empresa com a NIS2, o RGPD e o AI Act, e identificar as falhas e os riscos mais importantes;
- **Orientar** a empresa com um plano de ação claro e por prioridades, numa linguagem acessível a quem não é especialista;
- **Acompanhar** a conformidade ao longo do tempo, para que não seja um exercício pontual, mas um processo contínuo de melhoria;
- **Tornar acessível** um serviço de segurança e conformidade que, até agora, estava ao alcance sobretudo das grandes organizações.

1.3 Enquadramento Legal

O aLinha avalia a conformidade das PME com três diplomas europeus: a Diretiva NIS2, o RGPD e o AI Act. Os três têm objetivos diferentes, mas aplicam-se muitas vezes à mesma empresa e sobrepõem-se

em alguns pontos, como a gestão de risco ou a notificação de incidentes. Esta secção resume o que cada um exige às empresas abrangidas.

1.3.1 Diretiva NIS2 e Regime Jurídico da Cibersegurança

A NIS2 obriga as entidades de setores considerados críticos para a economia e a sociedade a gerir os seus riscos de cibersegurança e a reportar incidentes. Em Portugal, a transposição foi concluída através do Decreto-Lei n.º 125/2025, de 4 de dezembro de 2025, que aprova o novo Regime Jurídico da Cibersegurança, em vigor desde 3 de abril de 2026. Para concretizar este decreto-lei, foi publicado o Regulamento do Regime Jurídico da Cibersegurança (Regulamento n.º 756/2026, de 22 de junho), disponibilizado pelo Centro Nacional de Cibersegurança (CNCS), que é a autoridade nacional de cibersegurança.

O regime aplica-se a entidades públicas e privadas consideradas essenciais, importantes ou relevantes, classificação que depende do setor e da dimensão da organização. Para estar em conformidade, uma empresa abrangida tem de:

- **Registar-se junto do CNCS.** A plataforma eletrónica do CNCS é usada para a autoidentificação e qualificação das entidades, a comunicação do Responsável de Cibersegurança e do Ponto de Contacto Permanente, a submissão do Relatório Anual e a notificação de incidentes.
- **Nomear um Responsável de Cibersegurança.** É obrigatória a nomeação de um Responsável de Cibersegurança (CISO) e de um ponto de contacto permanente.
- **Implementar um sistema de gestão de risco.** É obrigatório um sistema de gestão de risco que cubra análise de riscos, incidentes, continuidade, ciclo de vida e cadeia de abastecimento, incluindo criptografia e autenticação multifator ou autenticação contínua, com relatório anual. Inclui ainda medidas como a formação dos trabalhadores, as políticas de segurança e a avaliação da eficácia das medidas adotadas.
- **Envolver o órgão de gestão.** O diploma impõe diligência e supervisão com responsabilidade pessoal por dolo ou culpa grave, exigindo decisões documentadas e integração da cibersegurança na governação de topo.
- **Notificar incidentes significativos dentro dos prazos.** A lei portuguesa exige alerta em 24h após a verificação, atualização até 72h, comunicação do fim de impacto em 24h e relatório final em 30 dias úteis após a notificação do fim de impacto.

A supervisão é proporcional à classificação: as Entidades Importantes são, regra geral, fiscalizadas de forma reativa, na sequência de incidentes, enquanto as essenciais estão sujeitas a supervisão proativa. Algumas obrigações têm um período de transição, já que certas disposições de gestão de risco, notificação de incidentes e supervisão só produzem efeitos 24 meses após a publicação da regulamentação do CNCS. O incumprimento pode resultar em coimas que, segundo a diretiva, chegam a 10 milhões de euros ou 2% do volume de negócios anual mundial para entidades essenciais, e a 7 milhões de euros ou 1,4% para entidades importantes.

1.3.2 Regulamento Geral sobre a Proteção de Dados (RGPD)

O RGPD aplica-se a qualquer empresa que trate dados pessoais, ou seja, praticamente todas, já que até os dados dos trabalhadores e dos clientes são dados pessoais. Em Portugal, é complementado pela Lei n.º 58/2019, e a autoridade de controlo é a Comissão Nacional de Proteção de Dados (CNPD). Para estar em conformidade, uma empresa tem de:

- **Tratar dados apenas com fundamento legal**, como o consentimento, a execução de um contrato ou uma obrigação legal, e respeitar princípios como a minimização dos dados e a limitação da sua conservação.
- **Informar as pessoas** sobre que dados recolhe, para quê e durante quanto tempo, normalmente através de uma política de privacidade.
- **Garantir os direitos dos titulares**, como o acesso, a retificação, o apagamento e a oposição, respondendo aos pedidos no prazo de um mês.
- **Manter um registo das atividades de tratamento**, que indica que dados são tratados, com que finalidade e por quem.
- **Aplicar medidas de segurança adequadas** aos dados pessoais, como o controlo de acessos, a cifragem e as cópias de segurança.
- **Celebrar contratos com subcontratantes** (por exemplo, fornecedores de software ou de serviços de TI) que tratem dados em seu nome.
- **Notificar violações de dados pessoais** à CNPD no prazo de 72 horas após ter conhecimento e, quando houver risco elevado, informar também as pessoas afetadas.
- **Em certos casos**, nomear um Encarregado de Proteção de Dados (DPO) e realizar avaliações de impacto sobre a proteção de dados.

As coimas podem chegar a 20 milhões de euros ou 4% do volume de negócios anual mundial, consoante o montante mais elevado.

1.3.3 Regulamento da Inteligência Artificial (AI Act)

O AI Act regula o desenvolvimento e a utilização de sistemas de IA segundo uma abordagem baseada no risco: quanto maior o risco de um sistema para as pessoas, mais exigentes são as obrigações. A maioria das PME não desenvolve sistemas de IA, mas utiliza-os (por exemplo, chatbots, ferramentas de recrutamento ou software com funcionalidades de IA), pelo que lhes cabem sobretudo as obrigações de quem utiliza. As principais são:

- **Não usar práticas proibidas.** A pontuação social, a IA manipuladora que explora vulnerabilidades, a identificação biométrica remota em tempo real em espaços públicos (com exceções restritas) e a recolha não direcionada de imagens faciais para criar bases de dados de reconhecimento continuam proibidas, e estas proibições já se aplicam.
- **Cumprir as obrigações de transparência.** Quem interage com um sistema de IA, como um chatbot, deve ser informado de que está a falar com uma máquina, e os conteúdos gerados ou manipulados por IA devem ser identificados como tal.
- **Promover a literacia em IA**, garantindo que os trabalhadores que usam estes sistemas tenham conhecimentos suficientes para o fazer de forma informada.
- **Cumprir requisitos reforçados nos sistemas de alto risco**, como os usados na seleção ou avaliação de trabalhadores. Quem os utiliza deve seguir as instruções do fornecedor, assegurar supervisão humana, monitorizar o funcionamento e informar os trabalhadores afetados.

O calendário destas obrigações foi revisto em 2026 pelo Regulamento (UE) 2026/1744 do Parlamento Europeu e do Conselho, de 8 de julho de 2026 (conhecido como AI Omnibus), publicado no Jornal Oficial da União Europeia a 24 de julho de 2026 e em vigor desde 27 de julho de 2026. Este regulamento altera o AI Act e adia os prazos de cumprimento das obrigações relativas a IA de alto risco: os novos prazos são 2 de dezembro de 2027 para os sistemas de alto risco autónomos e 2 de agosto de 2028 para os sistemas integrados em produtos. Traz ainda algum alívio às empresas mais pequenas, já que introduz

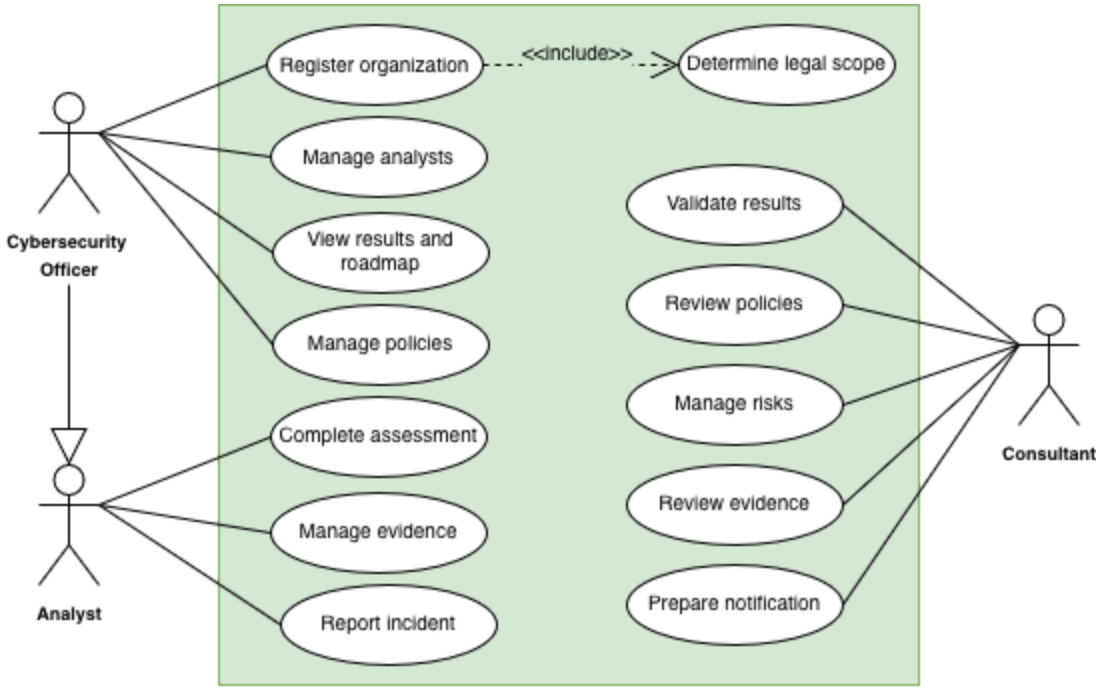
definições formais de PME e de pequenas empresas de média capitalização, com documentação técnica simplificada, requisitos de gestão da qualidade proporcionais e acesso prioritário a ambientes de testagem regulamentar.

2. Conceito do Produto

2.1 State of the Art

	OneTrust	DataGuard	Cynomi	Tradicional Consulting	alinha
NIS2 Framework Support	✓	✓	✓	✓	✓
Conversational Interface	✗	✗	✗	✗	✓
National Context	✗	✗	✗	✓	✓
CISO / HITL Assistance	✗	✓	✓	✓	✓
Low Budget	✗	✗	✗	✗	✓

2.2 Diagrama de Casos de Uso



2.3 Atores

Atores do lado do cliente

2.3.1 Responsável designado

O Responsável designado é a pessoa nomeada pela PME como responsável pela cibersegurança da organização, correspondendo ao Responsável de Cibersegurança que o Regime Jurídico da Cibersegurança obriga a designar (artigo 31.º). Na prática, esta função é muitas vezes atribuída a alguém da gestão sem formação técnica nem jurídica nesta área, que a acumula com outras responsabilidades. É essa lacuna de competências que o aLinha preenche: o Responsável designado assume formalmente a função, e a plataforma, com o apoio do consultor, dá-lhe o conhecimento e o acompanhamento de que precisa para a exercer (persona: Rui Santos).

O seu objetivo é perceber, em linguagem simples, o que a empresa tem de cumprir, ter um plano de ação priorizado e conseguir demonstrar a conformidade à administração, a clientes e a auditores. É ele quem cria a conta, regista a organização na plataforma e recebe a sugestão de enquadramento NIS2. A partir daí, convida e gere os analistas da sua organização, responde ao questionário de maturidade, consulta os resultados, as lacunas e o roadmap, e pede ao assistente de IA rascunhos de políticas. Reporta também incidentes e recebe as notificações validadas pelo prestador, que submete às autoridades competentes. Tem acesso a toda a informação de conformidade da sua organização, mas a nenhuma informação de outras organizações, e não pode publicar documentos sem validação do prestador.

O Responsável designado representa também o órgão de gestão da PME na plataforma. A NIS2 (art. 20.º) atribui ao órgão de gestão a aprovação das medidas de gestão de riscos de cibersegurança e a responsabilidade pelo seu cumprimento. Para não criar um ator adicional, optou-se por exigir que, ao aceitar formalmente uma política, o Responsável designado anexe a prova da sua aprovação pela

administração, por exemplo a ata da reunião ou um documento assinado. Desta forma, a plataforma mantém o registo da aprovação exigida por lei sem que os membros da administração precisem de conta própria.

2.3.2 Analista

O Analista é um colaborador interno da PME, ou um prestador externo de serviços de TI, a quem a organização atribui tarefas concretas de cibersegurança, como o técnico de informática. É criado por convite do Responsável designado (persona: Pedro Almeida).

O seu objetivo é cumprir as tarefas que lhe foram atribuídas sem ter de passar pelo Responsável designado. Pode responder às perguntas técnicas do questionário que lhe forem atribuídas, submeter as evidências pelas quais é responsável e realizar as ações de formação e sensibilização previstas nas políticas aprovadas. Pode também reportar incidentes, porque é muitas vezes quem os deteta primeiro, e qualquer atraso compromete o prazo de 24 horas para o alerta inicial. Ao contrário do Responsável designado, não tem acesso aos resultados globais da avaliação, ao roadmap completo, às políticas em rascunho nem ao acompanhamento dos incidentes, aplicando-se o princípio do menor privilégio.

A existência deste ator evita que o Responsável designado, sem formação técnica, seja intermediário de todas as evidências técnicas, o que tende a originar evidências incompletas ou no formato errado.

Atores do lado do prestador

2.3.3 Consultor

O Consultor é um profissional certificado da equipa aLinha que acompanha PMEs de diferentes setores (persona: Marta Ferreira). O seu objetivo é garantir que tudo o que chega ao cliente está correto e fundamentado na lei, reduzindo o tempo gasto em tarefas repetitivas.

É responsável pela validação humana do serviço. Revê e valida os resultados da avaliação e o roadmap antes de o cliente os ver, edita e aprova os rascunhos de políticas gerados pela IA, aceita ou rejeita evidências com comentário e, quando é reportado um incidente, prepara e valida as notificações exigidas pela lei portuguesa, do alerta inicial ao relatório final. Consulta também o estado de conformidade de todos os seus clientes e o histórico de alterações, para efeitos de auditoria. Só tem acesso às organizações que lhe estão atribuídas.

A atribuição de cada nova PME a um consultor é feita automaticamente pela plataforma, ao consultor com menor número de clientes ativos, pelo que não é necessário um ator de coordenação. A criação das contas dos consultores é feita em back-office e fica fora do âmbito deste projeto.

2.3.4 Atores secundários

Serviço de IA

Sistema externo que apoia a redação de rascunhos de políticas e de notificações, a priorização das ações do roadmap e a explicação de conceitos em linguagem simples. Interage com o Responsável designado através de um assistente conversacional e com o Consultor na preparação de documentos. Não tem persona nem user stories, por não ser uma pessoa, e as regras a que obedece estão definidas

como requisitos não funcionais. Nenhum documento ou resultado produzido pela IA chega ao cliente sem validação do Consultor; as explicações dadas pelo assistente são apenas informativas.

Serviço de notificações

Sistema externo de envio de emails, usado para alertar os utilizadores sobre prazos de conformidade e para avisar o Consultor de imediato quando é reportado um incidente.

Tempo

Representa os eventos acionados pela passagem do tempo, sem intervenção de um utilizador: as contagens dos prazos de notificação de incidentes e os lembretes de prazos de conformidade.

2.3.5 Entidades externas que não são atores

O CNCS, através da plataforma MyCiber, e a CNPD, no caso de violações de dados pessoais, recebem notificações das PMEs, mas não interagem diretamente com o aLinha, porque não existe integração com os seus sistemas. A plataforma prepara as notificações e é o Responsável designado quem as submete fora do sistema. Por esse motivo, estas entidades não são consideradas atores e não figuram no diagrama de casos de uso.

2.4 Personas

As três personas estão relacionadas entre si. O Rui e o Pedro trabalham para a mesma PME, e a Marta é a consultora a quem essa PME é atribuída.

Persona 1: Marta Ferreira, consultora (Consultor)

- **Idade:** 34 anos
- **Função:** Consultora de cibersegurança na equipa aLinha
- **Formação:** Mestrado em Engenharia Informática pela Universidade de Aveiro
- **Contexto:** Acompanha cerca de 12 PMEs em simultâneo, de setores diferentes. Passa grande parte do tempo a adaptar modelos de políticas, a perseguir clientes por causa de evidências e a controlar prazos em folhas de Excel.
- **Objetivos:**
    - Ver rapidamente que clientes precisam de atenção.
    - Reduzir o tempo gasto a escrever documentos repetitivos.
    - Garantir que tudo o que entrega está correto e bem fundamentado na lei.
- **Frustrações:**
    - A informação dos clientes está espalhada por emails e ficheiros.
    - Os clientes enviam evidências incompletas ou no formato errado.
    - Tem medo de falhar um prazo de notificação de incidente.
- **Como usa o aLinha:** Recebe automaticamente as novas PMEs que lhe são atribuídas e acompanha o estado de conformidade de todos os clientes num único painel. Valida os resultados, o roadmap e os rascunhos de políticas gerados pela IA, aceita ou rejeita evidências com comentário e prepara e valida as notificações de incidentes.
- **Citação:** *"Quero passar o meu tempo a analisar riscos, não a formatar documentos."*

Persona 2: Rui Santos, responsável da PME (Responsável designado)

- **Idade:** 47 anos
- **Função:** Diretor administrativo e financeiro, designado pela administração como responsável de cibersegurança. Não faz parte do conselho de administração, pelo que as decisões formais têm de ser aprovadas por este.
- **Empresa:** Fábrica de componentes para automóveis em Águeda, com 120 trabalhadores. É uma média empresa do setor da indústria transformadora e está abrangida pela NIS2, provavelmente como entidade importante.
- **Formação:** Licenciatura em Gestão. Não tem formação técnica em informática.
- **Contexto:** A empresa tem apenas um técnico de informática externo, que vem duas vezes por semana. O Rui soube da NIS2 por um email da associação empresarial. Sabe que a administração pode ser responsabilizada, mas não sabe por onde começar.
- **Objetivos:**
    - Perceber, em linguagem simples, o que a empresa tem de fazer.
    - Ter um plano claro e priorizado, sem ter de contratar um CISO a tempo inteiro.
    - Conseguir provar à administração, aos clientes e aos auditores que a empresa cumpre.
- **Frustrações:**
    - O vocabulário técnico e legal é difícil de interpretar.
    - Não tem tempo: a cibersegurança é só uma das suas muitas responsabilidades.
    - Tem medo das coimas e de não saber o que fazer se houver um ataque.
- **Como usa o aLinha:** Cria a conta e regista a empresa, recebendo a sugestão de enquadramento NIS2. Convida o técnico de informática para a plataforma, responde ao questionário de maturidade, consulta os resultados e o roadmap e pede ao assistente de IA rascunhos de políticas. Aceita as políticas aprovadas, anexando a ata da administração, submete as evidências não técnicas e acompanha os incidentes até receber a notificação pronta a submeter.
- **Citação:** *"Não preciso de ser especialista, preciso que me digam o que fazer e quando."*

Persona 3: Pedro Almeida, técnico de informática (Analista)

- **Idade:** 29 anos
- **Função:** Técnico de informática numa pequena empresa de serviços de TI, que presta apoio à fábrica do Rui duas vezes por semana
- **Formação:** Curso Técnico Superior Profissional em Tecnologias e Programação de Sistemas de Informação
- **Contexto:** Dá apoio a várias empresas da região ao mesmo tempo. Conhece bem os sistemas da fábrica (servidores, backups, rede e contas de utilizador), mas não conhece a NIS2 nem sabe que provas a lei exige. Os pedidos do Rui chegam-lhe por telefone ou email, muitas vezes sem que saiba bem o que é preciso.
- **Objetivos:**
    - Saber exatamente que tarefas e evidências lhe cabem e até quando.
    - Entregar cada evidência à primeira, no formato certo.
    - Ter uma forma rápida de alertar quando deteta algo suspeito.
- **Frustrações:**
    - Recebe pedidos vagos e tem de os repetir porque "não era bem isto".
    - Está na fábrica apenas dois dias por semana e perde tempo à espera de respostas.
    - Não sabe se deve avisar alguém, nem quem, quando vê um alerta de segurança.

- **Como usa o aLinha:** Entra na plataforma por convite do Rui. Responde às perguntas técnicas do questionário que lhe são atribuídas, submete evidências técnicas (por exemplo, registos de backups ou a configuração do MFA), faz as formações previstas e reporta incidentes quando os deteta.
- **Citação:** *"Digam-me o que precisam e em que formato, que eu trato do resto."*

2.5 Cenários

Cenário #1: Adesão à plataforma

Numa segunda-feira à tarde, depois de mais uma reunião em que a administração lhe perguntou o que a empresa está a fazer quanto à NIS2, o Rui decide finalmente tratar do assunto. Não sabe por onde começar e receia ter de contratar um especialista a tempo inteiro, algo que a fábrica não pode pagar.

O Rui cria uma conta no aLinha, protegida com autenticação multifator, e regista a empresa, indicando o NIF da empresa, o CAE, o setor, o número de trabalhadores e o volume de negócios. A plataforma informa-o de imediato de que a fábrica está provavelmente abrangida pela NIS2 como entidade importante, explica em linguagem simples o que isso implica e lembra-o de que a qualificação oficial será atribuída pelo CNCS após o registo no MyCiber. Mostra-lhe também que, além da NIS2, a empresa está sujeita ao RGPD, porque trata dados pessoais dos trabalhadores e dos clientes. A empresa fica automaticamente associada a uma consultora, a Marta. O Rui convida o Pedro, o técnico de informática, e começa a responder ao questionário de maturidade. Sempre que uma pergunta lhe parece demasiado técnica, consulta a explicação ao lado. As perguntas sobre servidores e backups atribui-as ao Pedro, que lhes responde quando está na fábrica. Atribui-lhe também o registo dos ativos técnicos da fábrica, como os servidores, a rede e os sistemas de produção, que o Pedro preenche no inventário da organização. Como tem de sair para uma reunião, o Rui guarda o progresso e termina o questionário dois dias depois.

User stories: US01, US10, US11, US12, US13, US14, US28, US32, US33, US34,US35

Cenário #2: Validação dos resultados

A Marta recebe a indicação de que a fábrica do Rui concluiu o questionário. Antes, cada diagnóstico obrigava-a a cruzar respostas enviadas por email com folhas de Excel, e passava horas a montar um relatório que o cliente muitas vezes não compreendia.

Ao abrir a avaliação no aLinha, a Marta encontra já calculados o nível de maturidade e as lacunas face ao nível alvo. Tem também uma proposta de roadmap preparada pela IA: uma lista de ações concretas, ordenadas por prioridade, cada uma com a obrigação legal a que responde, o prazo e a evidência necessária. Antes de validar, consulta o inventário de ativos preenchido pelo Pedro e regista no registo de riscos o risco de ransomware no servidor de produção, que classifica como elevado. É por isso que sobe a implementação do MFA (Multi-Factor Authentication) e o teste das cópias de segurança para o topo da lista. Depois valida o resultado. Só nesse momento o Rui passa a ver o diagnóstico, com a garantia de que foi revisto por um profissional certificado. No dia seguinte, o Rui exporta o relatório em PDF e apresenta-o à administração.

User stories: US02, US15, US16, US17,US36

Cenário #3: Aprovação de uma política

Uma das primeiras ações do roadmap da fábrica é criar uma política de cópias de segurança. O Rui nunca escreveu um documento destes e teme perder semanas a tentar perceber o que deve conter.

No aLinha, o Rui pede ao assistente de IA um rascunho da política, respondendo a algumas perguntas simples sobre a forma como a empresa guarda os seus dados. O rascunho segue para a Marta, que o ajusta à realidade da fábrica e o aprova. O Rui leva a versão final à reunião mensal da administração, onde é aprovada. De volta à plataforma, aceita formalmente a política e anexa a ata da reunião, ficando registado que a administração cumpriu a sua obrigação de aprovar as medidas de cibersegurança.

User stories: US03, US18, US19

Cenário #4: Submissão de evidências

O Pedro está na fábrica apenas às terças e quintas-feiras e apoia várias outras empresas no resto da semana. Até agora, os pedidos do Rui chegavam-lhe por telefone, sem indicação clara do que era preciso, e era frequente ter de repetir o trabalho.

Ao entrar no aLinha, o Pedro vê na sua lista uma tarefa que o Rui lhe atribuiu a partir do roadmap: provar que os backups dos servidores são feitos diariamente. Exporta o registo do software de backup e submete-o. No dia seguinte, a Marta rejeita a evidência com um comentário a explicar que o registo tem de mostrar também um teste de reposição. Na quinta-feira, o Pedro faz o teste, submete o novo registo e a evidência é aceite. Aproveita ainda para concluir a formação de sensibilização que lhe foi atribuída na plataforma. Entretanto, o Rui acompanha no dashboard as evidências que ainda faltam e recebe um email a lembrar que tem até à semana seguinte para submeter a lista de presenças da sessão de sensibilização dada aos restantes trabalhadores.

User stories: US04, US20, US21, US25, US26, US27, US29, US30

Cenário #5: Resposta a um incidente

Numa terça-feira, o Pedro chega à fábrica e descobre que vários ficheiros do servidor de produção estão cifrados e que há uma mensagem a exigir um resgate. Antes do aLinha, não saberia a quem avisar nem que prazos legais estariam em jogo.

O Pedro reporta o incidente na app em poucos minutos, descrevendo o que observou. A plataforma inicia de imediato a contagem decrescente das 24 horas para o alerta inicial e das 72 horas para a atualização, e a Marta e o Rui são notificados. Com a ajuda da IA, a Marta prepara o rascunho do alerta inicial, revê-o e valida-o. Ao início da tarde, o Rui recebe a notificação pronta a submeter e envia-a ao CNCS através do MyCiber, bem dentro do prazo. Como o servidor guardava também dados pessoais dos trabalhadores, a Marta prepara ainda a notificação à CNPD, exigida pelo RGPD no prazo de 72 horas. Na quinta-feira, o Rui submete a atualização do incidente, já com a avaliação da gravidade e do impacto.

Graças às cópias de segurança testadas semanas antes, o Pedro consegue repor os dados e, no sábado, a produção volta ao normal. Ao assinalar na plataforma o fim do impacto, inicia-se uma nova contagem de 24 horas para essa comunicação, que o Rui submete no domingo de manhã. A partir daí, o

aLinha passa a mostrar o prazo de 30 dias úteis para o relatório final, que a Marta vai preparando com o Rui à medida que a análise das causas do incidente avança.

User stories: US05, US06, US07, US23, US24, US31

Cenário #6: Acompanhamento da carteira de clientes

Numa segunda-feira, a Marta prepara a semana. Antes, isso significava abrir dezenas de emails e folhas de Excel para perceber que clientes tinham prazos a terminar ou evidências por entregar, sempre com o receio de deixar escapar alguma coisa.

Ao abrir o painel do aLinha, a Marta vê os seus 12 clientes ordenados pelo estado de conformidade. Duas empresas aparecem em destaque por terem evidências em atraso, e é por elas que começa. Como a fábrica do Rui vai ser auditada por um cliente do setor automóvel, consulta o histórico de alterações da organização, que mostra quem submeteu, aprovou ou alterou cada documento. Do lado da fábrica, o Rui acompanha no seu dashboard a evolução da cobertura de conformidade e os próximos prazos.

User stories: US08, US09, US25

2.6 User Stories

Consultor

User Story #US01: Atribuição automática de novos clientes (Prioridade Alta)
Como consultor, quero que as novas organizações sejam atribuídas automaticamente ao consultor com menos clientes ativos, para que a carga de trabalho fique equilibrada sem necessidade de coordenação manual.

“Dado que uma nova organização concluiu o seu registo
Quando o sistema a atribui a um consultor
Então a organização deve aparecer na minha carteira de clientes, se eu for o consultor com menos clientes ativos”

User Story #US02: Validar resultados e roadmap (Prioridade Alta)
Como consultor, quero rever e validar os resultados e o roadmap (plano de ação da empresa para chegar à conformidade) antes de o cliente os ver, para garantir que estão corretos.

“Dado que o cliente concluiu a avaliação de maturidade
Quando eu revejo, ajusto se necessário e valido os resultados e o roadmap gerados
Então estes só devem ficar visíveis para o cliente após a minha validação”

User Story #US03: Editar e aprovar rascunho de política (Prioridade Média)
Como consultor, quero editar e aprovar um rascunho de política pedido pelo cliente antes de ser publicado, para que nada chegue ao cliente sem revisão humana.

“Dado que o responsável designado pediu um rascunho de política ao assistente de IA
Quando eu edito e aprovo o rascunho
Então apenas a versão aprovada por mim deve ficar disponível para o cliente”

User Story #US04: Aceitar ou rejeitar evidências (Prioridade Média)
Como consultor, quero aceitar ou rejeitar evidências com um comentário, para garantir que provam o cumprimento.

Dado que um utilizador do cliente submeteu uma evidência
Quando eu analiso essa evidência
Então devo poder aceitá-la ou rejeitá-la, com um comentário visível para quem a submeteu."

User Story #US05: Notificação de incidente reportado (Prioridade Alta)
Como consultor, quero ser notificado quando um cliente reportar um incidente, para reagir de imediato.

"Dado que o responsável designado ou um analista de um dos meus clientes reporta um incidente de segurança
Quando o reporte é submetido
Então devo ser notificado de imediato"

User Story #US06: Preparar notificações de incidente com IA (Prioridade Alta)
Como consultor, quero preparar os rascunhos das notificações legais de incidente com ajuda da IA, para cumprir os prazos definidos pela lei portuguesa.

"Dado que foi reportado um incidente com impacto significativo
Quando inicio a preparação das notificações legais
Então devo receber, em cada fase, o rascunho da notificação correspondente (alerta inicial em 24h, atualização em 72h, comunicação do fim de impacto e relatório final), pronto a validar
E, se tiverem sido afetados dados pessoais, um rascunho da notificação à CNPD prevista no RGPD"**User Story #US07: Validar e entregar notificação ao cliente (Prioridade Alta)**
Como consultor, quero validar a notificação e entregá-la ao cliente, para que ele a submeta à autoridade competente.

"Dado que foi gerado um rascunho de notificação de incidente
Quando valido o seu conteúdo
Então a notificação validada deve ficar disponível para o responsável designado a submeter no MyCiber ou, no caso do RGPD, à CNPD"

User Story #US08: Dashboard da carteira de clientes (Prioridade Média)
Como consultor, quero ver todos os meus clientes com o respetivo estado de conformidade, para priorizar o meu trabalho.

Dado que tenho vários clientes atribuídos
Quando acedo ao dashboard
Então devo ver todos os meus clientes ordenados por estado de conformidade, com destaque para os que precisam de atenção

User Story #US09: Histórico de alterações (Prioridade Baixa)
Como consultor, quero consultar o histórico de quem alterou o quê, para garantir a auditabilidade.

Dado que foram feitas alterações no processo de um cliente
Quando consulto o histórico
Então devo ver quem alterou o quê, e quando

User Story #US36: Manter o registo de riscos (Prioridade Alta)
Como consultor, quero manter o registo de riscos de cada organização segundo a ISO/IEC 27005, para que o roadmap seja priorizado com base nos riscos reais da empresa.

“Dado que a organização tem o inventário de ativos preenchido
Quando identifico um risco sobre um ativo, indicando a probabilidade, o impacto e o tratamento
Então o sistema deve calcular o nível de risco e permitir ligar as medidas de mitigação às ações do roadmap”

User Story #US38: Ver a força das evidências (Prioridade Média)
Como consultor, quero ver a força de cada evidência (autodeclarada, documento verificado, tecnicamente verificada ou continuamente verificada), para saber o grau de confiança que posso ter no cumprimento de cada obrigação.

Dado que foram submetidas ou recolhidas evidências para uma organização
Quando analiso essas evidências
Então devo ver a classificação da força de cada uma, tida em conta no cálculo da conformidade

User Story #US39: Consultar a rastreabilidade da conformidade (Prioridade Média)
Como consultor, quero navegar de cada requisito legal até aos controlos, lacunas, ações e evidências associados, para demonstrar o cumprimento de forma fundamentada numa auditoria.

Dado que a organização tem uma avaliação validada
Quando seleciono um requisito legal
Então devo ver os controlos que o cumprem, as lacunas identificadas, as ações do roadmap e as evidências que o comprovam

Responsável designado

User Story #US10: Criar conta e registar organização (Prioridade Alta)
Como responsável designado, quero criar uma conta e registar a minha organização com os dados necessários ao enquadramento (NIF, CAE, setor, dimensão, entre outros), para que a empresa comece a usar a plataforma.

Dado que não tenho conta na plataforma
Quando crio uma conta e registo a organização com os dados pedidos
Então a organização deve ficar registada e associada à minha conta

User Story #US11: Enquadramento NIS2 da organização (Prioridade Alta)
Como responsável designado, quero que o sistema sugira a título indicativo o enquadramento NIS2 da minha organização (essencial, importante ou não abrangida) e me permita registar a qualificação oficial atribuída pelo CNCS, para saber que obrigações se aplicam.

“Dado que a minha organização está registada com os dados necessários ao enquadramento
Quando o sistema analisa esses dados
Então devo ver o enquadramento sugerido (entidade essencial, importante ou não abrangida) e uma explicação simples do que isso implica
E, quando receber o Ato de Qualificação do CNCS, devo poder registar a qualificação oficial, que passa a substituir a sugestão da plataforma”

User Story #US12: Convidar analistas (Prioridade Alta)
Como responsável designado, quero convidar analistas da minha organização para a plataforma, para que realizem as tarefas que lhes forem atribuídas.

“Dado que a minha organização está registada
Quando envio um convite para o email de um analista
Então o analista deve receber um convite para criar uma conta com acesso restrito”

User Story #US13: Responder à avaliação e guardar o progresso (Prioridade Alta)
Como responsável designado, quero responder à avaliação de maturidade e guardar o progresso, para a completar em várias sessões.

Dado que a minha organização está registada
Quando respondo a parte do questionário e o guardo
Então devo poder retomá-lo mais tarde a partir do ponto onde parei

User Story #US14: Atribuir perguntas e tarefas a analistas (Prioridade Alta)
Como responsável designado, quero atribuir perguntas técnicas e evidências a analistas, para que cada tarefa fique com quem conhece o assunto.

Dado que pelo menos um analista aderiu à minha organização
Quando atribuo uma pergunta ou uma evidência a um analista
Então essa tarefa deve aparecer na lista de tarefas do analista

User Story #US15: Ver nível atual, nível alvo e lacunas (Prioridade Alta)
Como responsável designado, quero ver o nível atual, o nível alvo e as lacunas, para perceber em que ponto está a empresa.

Dado que o consultor validou os resultados da avaliação
Quando acedo aos resultados
Então devo ver o nível atual, o nível alvo e as lacunas identificadas

User Story #US16: Roadmap priorizado (Prioridade Alta)
Como responsável designado, quero um roadmap de ações priorizado, para saber por onde começar.

Dado que o consultor validou o roadmap
Quando acedo ao roadmap
Então devo ver as ações ordenadas por prioridade, com prazos

User Story #US17: Exportar relatório em PDF (Prioridade Baixa)
Como responsável designado, quero exportar o relatório em PDF, para o mostrar à administração ou a auditores.

Dado que os resultados da avaliação foram validados
Quando peço a exportação
Então devo receber um PDF com o nível, as lacunas e o roadmap

User Story #US18: Pedir rascunho de política ao assistente de IA (Prioridade Média)
Como responsável designado, quero pedir um rascunho de política ao assistente de IA, para não ter de a escrever do zero.

Dado que o roadmap inclui a criação de uma política
Quando respondo às perguntas do assistente de IA sobre a minha organização
Então deve ser gerado um rascunho, enviado ao meu consultor para revisão

User Story #US19: Aceitar políticas aprovadas (Prioridade Média)
Como responsável designado, quero aceitar formalmente as políticas aprovadas, anexando a prova da aprovação pela administração, para que fique registada a adoção pela gestão de topo.

Dado que uma política foi aprovada pelo consultor
Quando a aceito e anexo a aprovação da administração (por exemplo, a ata da reunião)
Então a política deve ficar marcada como adotada, com a prova de aprovação guardada

User Story #US20: Submeter evidências (Prioridade Média)
Como responsável designado, quero submeter evidências para cada obrigação, para provar o cumprimento.

Dado que uma obrigação exige uma evidência
Quando carrego a evidência
Então esta deve ser enviada ao consultor para análise

User Story #US21: Ver evidências em falta ou rejeitadas (Prioridade Média)
Como responsável designado, quero ver que evidências estão em falta ou foram rejeitadas, para as mandar corrigir.

Dado que foram pedidas evidências à minha organização
Quando acedo à lista de evidências
Então devo ver o estado de cada uma e, se tiver sido rejeitada, o comentário do consultor

User Story #US22: Reportar incidente (Prioridade Alta)
Como responsável designado, quero reportar um incidente rapidamente, para iniciar os prazos legais.

Dado que estou autenticado na plataforma
Quando submeto o reporte de um incidente
Então o incidente deve ficar registado e as contagens dos prazos legais devem começar

User Story #US23: Contagem decrescente dos prazos (Prioridade Alta)
Como responsável designado, quero ver a contagem decrescente de cada prazo de notificação, para não falhar nenhum.

Dado que foi reportado um incidente
Quando consulto o incidente
Então devo ver o tempo restante para o alerta inicial (24h) e para a atualização (72h)
E, quando o impacto significativo terminar, o tempo restante para a comunicação do fim de impacto (24h) e para o relatório final (30 dias úteis)

User Story #US24: Receber a notificação validada (Prioridade Alta)
Como responsável designado, quero receber a notificação validada, pronta a submeter, para a enviar à autoridade competente.

Dado que o consultor validou uma notificação de incidente
Quando acedo ao incidente
Então devo poder descarregar a notificação, pronta a submeter no MyCiber ou, no caso do RGPD, à CNPD

User Story #US25: Dashboard de conformidade (Prioridade Alta)
Como responsável designado, quero um dashboard com a cobertura de conformidade, as lacunas e os próximos prazos, para acompanhar o progresso.

Dado que a minha organização tem uma avaliação validada
Quando acedo ao dashboard
Então devo ver a cobertura de conformidade, as lacunas por resolver e os próximos prazos

User Story #US26: Alertas de prazos por email (Prioridade Baixa)
Como responsável designado, quero receber alertas de prazos por email, para não me esquecer.

Dado que um prazo se está a aproximar
Quando é atingida a data do alerta
Então devo receber um email com o prazo e a tarefa pendente

User Story #US34: Ver o âmbito regulatório da organização (Prioridade Alta)

Como responsável designado, quero saber quais dos quadros legais (NIS2, RGPD e AI Act) se aplicam à minha organização, para perceber todas as obrigações que tenho de cumprir e não apenas as de cibersegurança.

Dado que a minha organização está registada
Quando o sistema analisa os dados da organização e as respostas sobre o tratamento de dados pessoais e o uso de sistemas de IA
Então devo ver os quadros legais aplicáveis, com uma explicação simples de cada um.

User Story #US35: Registar o inventário de ativos (Prioridade Alta)

Como responsável designado, quero registar os serviços críticos e os ativos da organização, com a ajuda dos analistas, para saber o que a empresa tem de proteger e cumprir a obrigação de comunicar a Lista de Ativos ao CNCS.

Dado que a minha organização está registada
Quando registo um ativo, indicando o responsável e a criticidade, ou atribuo esse registo a um analista
Então o ativo deve ficar no inventário da organização e disponível para a análise de riscos.

Analista

User Story #US27: Ver tarefas atribuídas (Prioridade Alta)
Como analista, quero ver apenas as tarefas que me foram atribuídas, para saber exatamente o que tenho de fazer e até quando.

Dado que o responsável designado me atribuiu tarefas
Quando acedo à plataforma
Então devo ver as minhas tarefas com os respetivos prazos, sem qualquer outra informação da organização

User Story #US28: Responder às perguntas técnicas atribuídas (Prioridade Alta)
Como analista, quero responder às perguntas técnicas que me foram atribuídas, para que a avaliação reflita o estado real dos sistemas.

Dado que me foram atribuídas perguntas técnicas
Quando lhes respondo
Então as minhas respostas devem ser incluídas na avaliação da organização

User Story #US29: Submeter evidências atribuídas (Prioridade Média)
Como analista, quero submeter as evidências que me foram atribuídas, para não depender do responsável designado para as entregar.

Dado que me foi atribuída uma evidência
Quando a carrego
Então esta deve ser enviada ao consultor para análise, e devo ver o comentário em caso de rejeição

User Story #US30: Realizar formação de sensibilização (Prioridade Média)
Como analista, quero realizar a formação de sensibilização prevista nas políticas aprovadas, para seguir boas práticas de cibersegurança.

Dado que me foi atribuída uma ação de formação
Quando a concluo
Então a minha conclusão deve ficar registada como evidência da organização

User Story #US31: Reportar incidente (Prioridade Alta)
Como analista, quero reportar um incidente assim que o detete, para que os prazos legais comecem sem esperar pelo responsável designado.

Dado que detetei um possível incidente de segurança
Quando submeto o reporte do incidente
Então o incidente deve ficar registado, e o responsável designado e o consultor devem ser notificados

User Story #US37: Ligar fontes de evidências (Prioridade Média)

Como analista, quero ligar sistemas da organização à plataforma (por exemplo, o repositório de código ou o serviço de identidade), com acesso apenas de leitura, para que as evidências técnicas sejam recolhidas automaticamente sem eu ter de as exportar.

Dado que o responsável designado me atribuiu a ligação de uma fonte de evidências
Quando autorizo o acesso só de leitura a esse sistema
Então a plataforma deve passar a recolher automaticamente as evidências correspondentes e associá-las às obrigações respetivas

Todos os utilizadores

User Story #US32: Autenticação segura com MFA (Prioridade Alta)
Como utilizador da plataforma, quero entrar com autenticação multifator, para proteger os dados sensíveis da minha organização.

Dado que tenho conta na plataforma
Quando entro com a palavra-passe e um segundo fator
Então só devo ter acesso depois de ambos serem verificados

User Story #US33: Explicação simples das perguntas (Prioridade Alta)
Como utilizador do cliente (responsável designado ou analista), quero ver uma explicação simples de cada pergunta, para responder sem ser especialista.

Dado que estou a responder ao questionário
Quando abro a explicação de uma pergunta
Então devo ver o que significa em linguagem simples, com um exemplo

3. Requisitos

3.1 Requisitos Funcionais

3.1.1 Gestão da Organização

Gerir as organizações, os seus utilizadores e o âmbito regulatório que lhes é aplicável.

RF01 – O sistema deve permitir que o Responsável designado crie uma conta e registe a sua organização, indicando os dados necessários ao enquadramento no Regime Jurídico da Cibersegurança: denominação, NIF, código CAE, setor e subsetor de atividade, serviços prestados, número de trabalhadores, volume de negócios, sede e contactos. (US10)

RF02 – O sistema deve sugerir, a título indicativo, o enquadramento da organização (entidade essencial, importante ou não abrangida), com uma explicação simples, e permitir registar a qualificação oficial atribuída pelo CNCS no Ato de Qualificação. (US11)

RF03 – O sistema deve determinar o âmbito regulatório da organização, identificando quais dos quadros legais (NIS2, RGPD e AI Act) lhe são aplicáveis. (US34)

RF04 – O sistema deve atribuir automaticamente cada nova organização ao consultor com menos clientes ativos. (US01)

RF05 – O sistema deve permitir que o Responsável designado convide analistas por email, criando contas com acesso restrito. (US12)

RF06 – O sistema deve permitir que o Responsável designado atribua perguntas, evidências e tarefas a analistas. (US14)

3.1.2 Avaliação de Maturidade e Conformidade

Avaliar o nível de maturidade da organização e identificar as lacunas de conformidade.

RF07 – O sistema deve disponibilizar um questionário de maturidade adaptado ao âmbito regulatório da organização, permitindo guardar o progresso e retomá-lo mais tarde. (US13)

RF08 – O sistema deve permitir que os analistas respondam às perguntas técnicas que lhes foram atribuídas, integrando as respostas na avaliação da organização. (US28)

RF09 – O sistema deve apresentar, para cada pergunta, uma explicação em linguagem simples, com um exemplo. (US33)

RF10 – O sistema deve calcular o nível de maturidade atual, o nível alvo e as lacunas de conformidade da organização. (US15)

RF11 – O sistema só deve disponibilizar os resultados ao cliente depois de validados pelo consultor. (US02, US15)

RF12 – O sistema deve permitir exportar o relatório de resultados em PDF. (US17)

3.1.3 Remediação e Evidências

Priorizar as ações necessárias para chegar à conformidade e gerir as evidências que comprovam o seu cumprimento.

RF13 – O sistema deve gerar um roadmap de ações priorizado, em que cada ação indica a obrigação legal a que responde, a prioridade, o prazo, o responsável e a evidência necessária. (US02, US16)

RF14 – O sistema deve permitir que o consultor ajuste e valide o roadmap antes de este ficar visível para o cliente. (US02)

RF15 – O sistema deve permitir a submissão de evidências pelo Responsável designado e pelos analistas, estes apenas para as evidências que lhes foram atribuídas. (US20, US29)

RF16 – O sistema deve permitir que o consultor aceite ou rejeite cada evidência, com um comentário visível para quem a submeteu. (US04)

RF17 – O sistema deve apresentar o estado de cada evidência (em falta, submetida, aceite ou rejeitada). (US21)

RF18 – O sistema deve apresentar a cada analista apenas as tarefas que lhe foram atribuídas, com os respetivos prazos. (US27)

RF19 – O sistema deve registar a conclusão das ações de formação como evidência da organização. (US30)

RF20 – O sistema deve permitir que o Responsável designado aceite formalmente as políticas aprovadas, anexando a prova da aprovação pela administração. (US19)

3.1.4 CISO Assistido por IA

Explicar requisitos legais, apoiar decisões e produzir documentação, sempre sujeita a validação humana.

RF21 – O sistema deve disponibilizar um assistente de IA que explique requisitos e conceitos legais em linguagem simples, com base apenas na legislação de referência da plataforma, identificando as respostas como geradas por IA e permitindo ao utilizador pedir esclarecimento ao consultor. (US11, US33)

RF22 – O sistema deve propor, com recurso à IA, a priorização das ações do roadmap. (US02, US16)

RF23 – O sistema deve permitir que o Responsável designado peça ao assistente de IA rascunhos de políticas, a partir de perguntas sobre a organização. (US18)

RF24 – O sistema deve enviar todos os rascunhos gerados pela IA ao consultor, que os pode editar e aprovar antes de ficarem disponíveis para o cliente. (US03)

RF25 – O sistema deve gerar, com recurso à IA, os rascunhos das notificações legais de incidente: as notificações ao CNCS e, quando haja dados pessoais afetados, a notificação à CNPD. (US06)

3.1.5 Monitorização e Apoio a Incidentes

Acompanhar o estado de conformidade, os prazos e o processo de notificação de incidentes.

RF26 – O sistema deve apresentar ao consultor um dashboard com todos os seus clientes, ordenados por estado de conformidade, com destaque para os que precisam de atenção. (US08)

RF27 – O sistema deve apresentar ao Responsável designado um dashboard com a cobertura de conformidade, as lacunas por resolver e os próximos prazos. (US25)

RF28 – O sistema deve enviar alertas por email quando um prazo se aproxima. (US26)

RF29 – O sistema deve permitir consultar o histórico de alterações de cada organização (quem alterou o quê, e quando). (US09)

RF30 – O sistema deve permitir que o Responsável designado e os analistas reportem um incidente de segurança. (US22, US31)

RF31 – O sistema deve notificar de imediato o consultor e o Responsável designado quando é reportado um incidente. (US05, US31)

RF32 – O sistema deve iniciar e apresentar as contagens decrescentes dos prazos legais: alerta inicial (24h) e atualização (72h) e, após o fim do impacto, a respetiva comunicação (24h) e o relatório final (30 dias úteis). (US22, US23)

RF33 – O sistema deve permitir que o consultor valide cada notificação e a disponibilize ao Responsável designado, pronta a submeter no MyCiber ou à CNPD. (US07, US24)

RF34 – O sistema deve apresentar ao Responsável designado e aos analistas um contacto de emergência do consultor, visível no dashboard e incluído nos emails de alerta, para que o reporte de incidentes possa ser feito mesmo quando a plataforma estiver indisponível. (US22, US31)

3.1.6 Gestão de Ativos e Riscos

Identificar os serviços e ativos críticos da organização e gerir os riscos a que estão expostos.

RF35 – O sistema deve permitir registar o inventário de serviços críticos e ativos da organização, indicando para cada um o responsável e a criticidade. (US35; Regulamento n.º 756/2026 – Lista de Ativos)

RF36 – O sistema deve manter um registo de riscos segundo a ISO/IEC 27005, indicando para cada risco o ativo afetado, a probabilidade, o impacto, o nível de risco e o tratamento definido. (US36)

3.1.7 Evidências e Rastreabilidade

Recolher evidências de forma automática, avaliar a sua fiabilidade e ligar cada obrigação legal às provas do seu cumprimento.

RF37 – O sistema deve recolher evidências técnicas automaticamente através de plugins Provider ligados aos sistemas do cliente, com acesso apenas de leitura. (US37)

RF38 – O sistema deve classificar a força de cada evidência como autodeclarada, documento verificado, tecnicamente verificada ou continuamente verificada. (US38)

RF39 – O sistema deve manter a rastreabilidade entre requisito legal, controlo, lacuna, ação e evidência. (US39)

3.2 Requisitos Não Funcionais

3.2.1 Disponibilidade e Fiabilidade

RNF01 – Disponibilidade mensal de 99% (máximo de aproximadamente 7h12m de indisponibilidade por mês).

RNF02 – Nenhum job em segundo plano é perdido em caso de falha de um componente (transactional outbox).

3.2.2 Multi-tenancy e Auditabilidade

RNF03 – Nenhum tenant pode ler ou alterar dados pertencentes a outro tenant.

RNF04 – 100% das operações de escrita em avaliações, resultados e documentos gerados são registadas no Audit Trail (quem, quando, o quê, tenant), sem qualquer possibilidade de edição ou eliminação, salvo em casos onde sejam guardados dados pessoais nesse mesmo Audit Trail.

RNF05 – O resultado de uma avaliação é calculado estritamente com base nas regras versionadas do Compliance Engine; a mesma entrada com a mesma versão do catálogo produz sempre o mesmo resultado.

3.2.3 Segurança

RNF06 – A aplicação não apresenta vulnerabilidades de gravidade alta ou crítica nas categorias OWASP Top 10.

RNF07 – 100% dos endpoints, exceto o login e o health check, requerem um token OIDC válido.

RNF08 – Cada endpoint está associado a funções explícitas; nenhum utilizador acede a operações fora do seu papel (Consultor, Responsável designado e Analista).

RNF9 – Todo o tráfego externo utiliza TLS 1.2 ou superior; não existem segredos presentes no código ou em ficheiros de configuração versionados.

RNF10 – Os ficheiros carregados são tratados como não fidedignos: processados na Sandbox de Documentos, sem acesso à internet e permitindo apenas tipos de ficheiro autorizados.

3.2.4 Inteligência Artificial

RNF11 – O Serviço de IA não tem acesso de escrita aos dados; todo o acesso da IA passa pelo Gateway de IA.

RNF12 – Nenhum documento ou resultado gerado pela IA destinado ao cliente (políticas, roadmaps, resultados de avaliação e notificações) é publicado sem a aprovação registada de um consultor. As respostas informativas do assistente de IA estão isentas desta validação, mas são sempre identificadas como geradas por IA. Adicionalmente, o utilizador deve ser sempre informado de que está a interagir

com um sistema de IA, e os conteúdos gerados por IA devem estar identificados como tal, em conformidade com o AI Act.

RNF13 – Os dados pessoais são removidos ou anonimizados antes de qualquer pedido ao LLM externo, e o fornecedor processa os dados na UE.

RNF14 – Cada output da IA regista o modelo, a versão do prompt, as fontes utilizadas e a data.

RNF15 – Os dados pessoais devem ser alojados na União Europeia, limitados ao necessário e conservados apenas durante o período definido, em conformidade com o RGPD: os dados pessoais serão mantidos durante a vigência do contrato da organização, após eliminação da conta, os dados serão apagados da base de dados e backups num prazo máximo de 30 dias após a rescisão e os Audit Trails serão conservados por 1 ano para efeitos de segurança e posteriormente anonimizados.

3.2.5 Desempenho, Extensibilidade e Operação

RNF16 – Com 50 utilizadores concorrentes: p95 abaixo de 500 ms para leituras de API e abaixo de 2 s para submissão de avaliações (excluindo chamadas ao LLM).

RNF17 – A adição de um plugin não requer alterações ao código do Core, e nenhum plugin acede ao interior de outro plugin.

RNF18 – Uma nova versão de um catálogo de framework (ex: NIS2, SOC-CMM) é carregada como dados, sem necessidade de recompilar ou reimplantar código.

RNF19 – O Core e os plugins têm uma cobertura de testes de pelo menos 70%; o CI corre em cada pull request e bloqueia o merge se falhar.

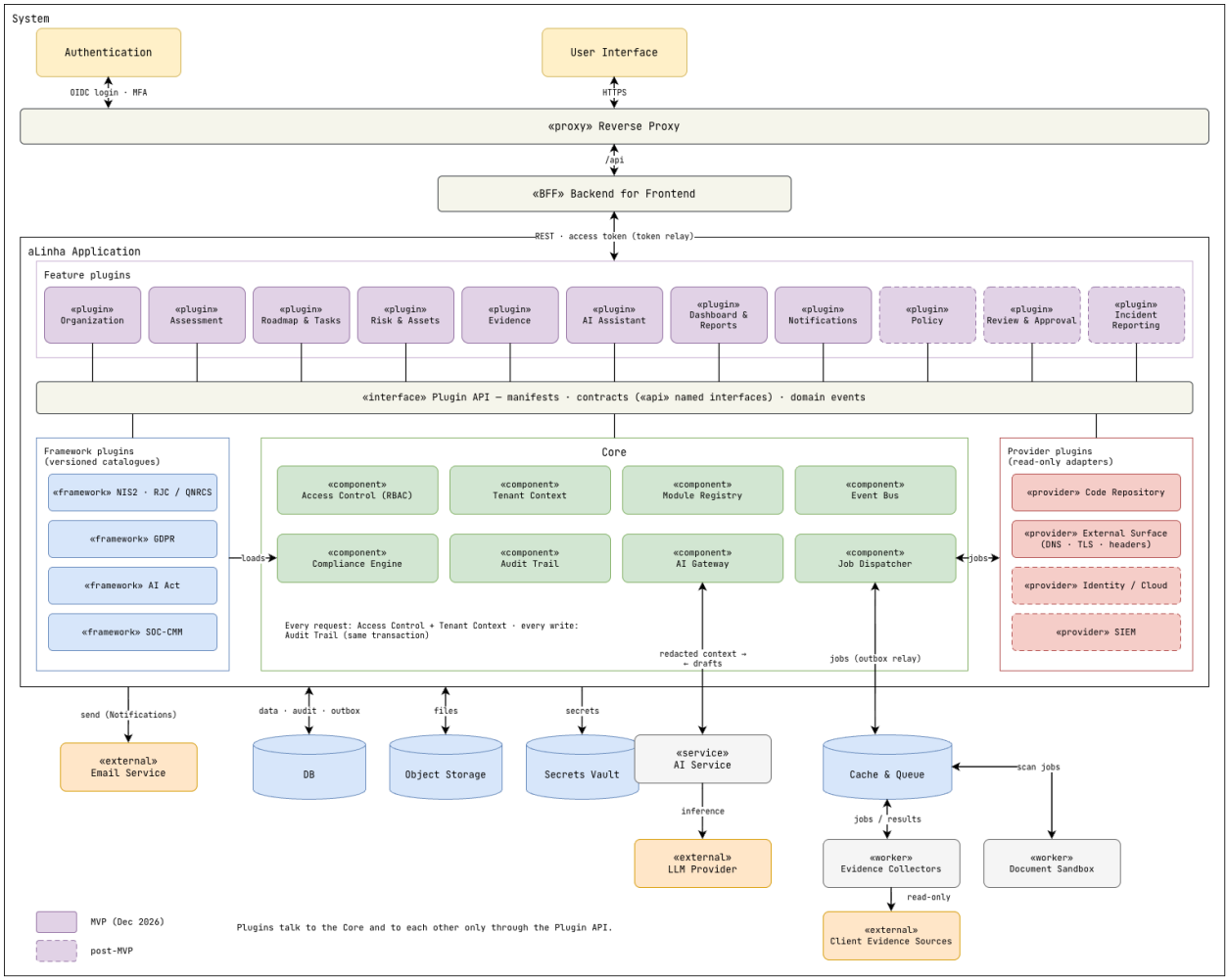
RNF20 – Todos os serviços expõem métricas e logs centralizados (Prometheus e Loki), com ID de tenant e de correlação, não contendo dados pessoais nos logs.

RNF21 – O sistema completo arranca com um único comando (Docker) num ambiente limpo, em menos de 15 minutos, seguindo a documentação.

A interface deve estar em português e usar linguagem simples, acessível a utilizadores sem formação técnica ou jurídica. Verificação: testes de usabilidade com utilizadores representativos.

4. Notebook da Arquitetura

4.1 Visão geral



O aLinha segue uma arquitetura por plugins. Um core pequeno e estável fornece as capacidades comuns, e os plugins implementam o negócio. Assim, a plataforma pode crescer em leis, fontes de evidência e funcionalidades sem alterar a base. O diagrama acima mostra a visão lógica da plataforma; os componentes a tracejado ficam para depois do MVP (dezembro de 2026). O MVP inclui o core completo, os plugins Organização, Avaliação, Riscos e Ativos, Dashboard e Relatórios e Notificações, os quadros NIS2/QNRCS e SOC-CMM, os providers de repositório de código e de superfície externa e o Serviço de IA. Ficam para depois as Políticas e Evidências, a Revisão e Aprovação, o Reporte de Incidentes, os quadros RGPD e AI Act, os providers de identidade, cloud e SIEM, a Sandbox de Documentos, o armazenamento de objetos, a monitorização e as cópias de segurança externas.

A arquitetura segue três princípios:

- **Isolamento entre plugins:** os plugins comunicam com o core e entre si apenas pela Plugin API (contratos e eventos de domínio), nunca pelo interior uns dos outros.
- **Conformidade determinística:** o estado de cada controlo resulta de regras versionadas e de evidências, nunca de um modelo de linguagem.
- **A IA assiste, o humano decide:** nenhum documento ou resultado gerado por IA chega ao cliente sem aprovação do consultor.

O core concentra o que é comum a todos os plugins: controlo de acessos por papel (RBAC), contexto do tenant, registo de módulos, barramento de eventos, motor de conformidade, registo de logs, despacho de tarefas e Gateway de IA. O negócio está dividido em três tipos de plugin:

Tipo	Responsabilidade	Exemplos
Feature	Funcionalidades usadas pelo utilizador	Organização, avaliação, roadmap, riscos e ativos, evidências, dashboard, notificações
Framework	Quadros legislativos	NIS2, RGPD, AI Act, QNRCS, SOC-CMM
Provider	Ligação a sistemas externos, em read-only	Repositório de código, superfície externa (DNS, TLS, cabeçalhos), identidade e cloud, SIEM

4.2 Escolha das tecnologias

O core é feito em Kotlin com Spring Boot e Spring Modulith. Cada plugin é um módulo da mesma aplicação, e não um serviço separado: não há chamadas de rede entre plugins, cada módulo tem o seu próprio esquema na base de dados e o Spring Modulith verifica no CI que nenhum módulo acede ao interior de outro. O Spring Boot oferece ainda autorização e isolamento entre clientes centralizados, e transações que gravam cada alteração junto com o registo de auditoria. É mais complexo do que as alternativas, mas estas garantias compensam.

O Python é usado apenas onde é necessário: no Serviço de IA (FastAPI), por ser onde existe o ecossistema de modelos de linguagem, e no Worker Runtime, que recolhe evidências e analisa documentos. Nos restantes componentes usámos soluções já existentes em vez de as construir de raiz, e todos os serviços correm em contentores Docker.

Componente	Tecnologia
Core	Kotlin, Spring Boot e Spring Modulith
IA e workers	Python (FastAPI no Serviço de IA)
Interface	React, Vite e TypeScript

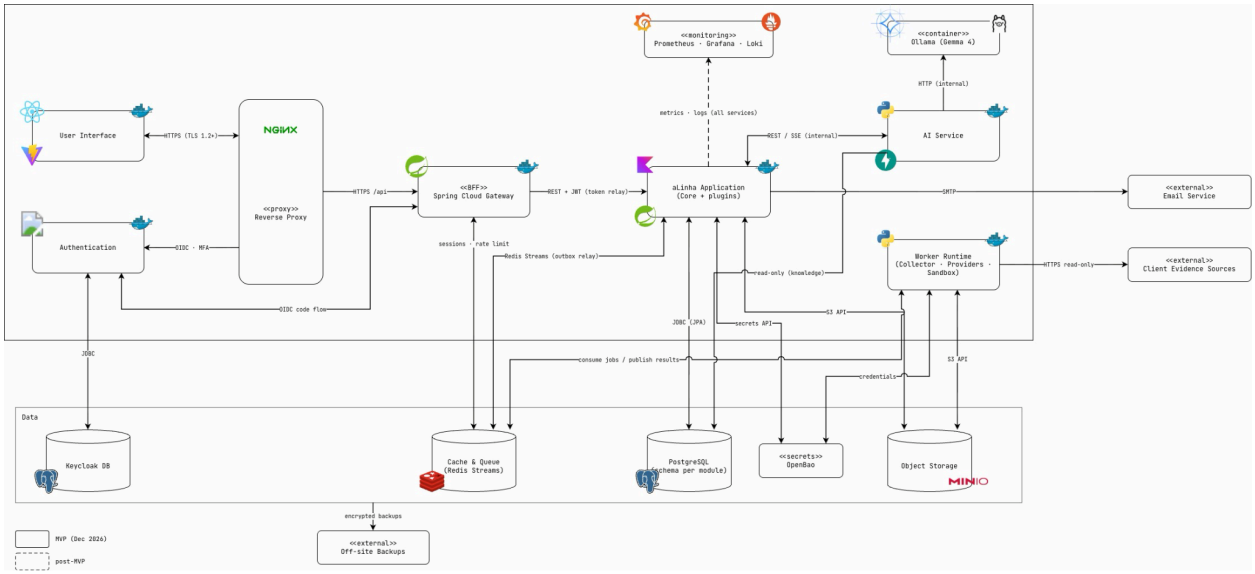
Componente	Tecnologia
Proxy inverso	Nginx
Autenticação	Keycloak, com MFA
Base de dados	PostgreSQL, um esquema por módulo (fonte de verdade)
Cache e filas	Redis Streams: sessões, limitação de pedidos e fila de tarefas (via transactional outbox)
BFF	Spring Cloud Gateway
LLM	Fornecedor de LLM abstraído pelo Serviço de IA
Ficheiros	MinIO (API S3), pós-MVP
Segredos	OpenBao
Monitorização	Prometheus, Grafana, Loki (pós-MVP)

4.3 Vista de implantação

O diagrama de implantação mostra os contentores Docker que compõem a plataforma e a forma como comunicam:

- O utilizador acede à interface (React) por HTTPS, com TLS 1.2 ou superior, através do Nginx, que é o único ponto de entrada.
- O BFF (Spring Cloud Gateway) faz o login com o Keycloak (OIDC com MFA), guarda a sessão no Redis e limita o número de pedidos. Os tokens nunca chegam ao browser: o BFF vai encaminhar cada pedido para a aplicação com o token de acesso do utilizador.

- A aplicação aLinha (core e plugins) guarda os dados no PostgreSQL, com um esquema por módulo, lê os segredos do OpenBao e, depois do MVP, guarda os ficheiros no MinIO.
- As tarefas assíncronas são gravadas numa outbox no PostgreSQL e publicadas no Redis Streams. O Worker Runtime consome-as, recolhe evidências dos sistemas do cliente apenas em leitura e devolve os resultados pela mesma fila. Depois do MVP, analisa também os ficheiros carregados na sandbox.
- O Serviço de IA recebe pedidos internos da aplicação, consulta a base de conhecimento em modo só de leitura e envia o prompt, já anonimizado, a um fornecedor de LLM. O fornecedor fica abstraído pelo Serviço de IA, pelo que pode ser trocado sem alterar o resto da plataforma.
- Os emails são enviados por SMTP para um serviço externo. Depois do MVP, todos os serviços passam a enviar métricas e logs para o Prometheus, o Loki e o Grafana, e as cópias de segurança passam a ser cifradas e guardadas fora das instalações.

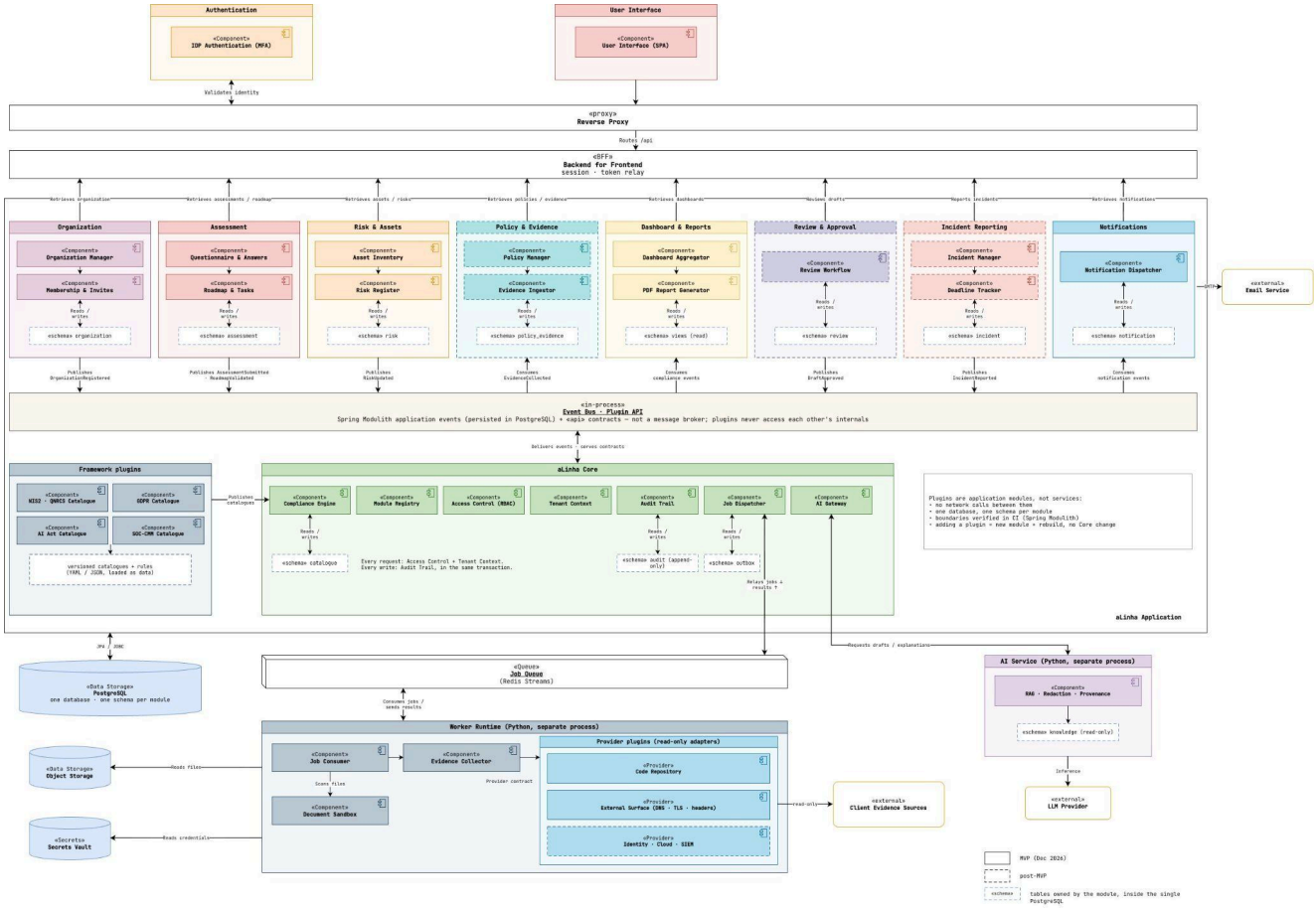


4.4 Vista de componentes

O diagrama de componentes mostra o interior da aplicação aLinha e dos dois serviços em Python.

Plugins de funcionalidade. Cada plugin (Organização, Avaliação, Riscos e Ativos, Políticas e Evidências, Dashboard e Relatórios, Revisão e Aprovação, Incidentes e Notificações) tem os seus próprios componentes e o seu próprio esquema na base de dados. Políticas e Evidências, Revisão e Aprovação e Incidentes ficam para depois do MVP. Os plugins comunicam entre si através de eventos de domínio, como AssessmentSubmitted ou IncidentReported, publicados no barramento de eventos do Spring Modulith e guardados no PostgreSQL.

Motor de conformidade. É a fonte de verdade do estado de cada organização. Carrega os catálogos dos plugins Framework, que são regras versionadas em YAML ou JSON, e mantém um catálogo único de controlos, pelo que o mesmo controlo pode satisfazer vários quadros legais. A rastreabilidade liga Requisito → Controlo → Lacuna → Ação → Política ou Evidência.
Evidências. São carregadas pelos utilizadores ou recolhidas automaticamente pelos plugins Provider, que correm no Worker Runtime e acedem aos sistemas do cliente apenas em leitura. Os ficheiros carregados são tratados como não fiáveis e analisados na Sandbox de Documentos. No MVP, as evidências vêm dos providers de repositório de código e de superfície externa e alimentam a Avaliação através do evento EvidenceCollected; o carregamento de ficheiros e a sandbox ficam para depois do MVP. A força de cada evidência é classificada como autodeclarada, documento verificado, tecnicamente verificada ou continuamente verificada.
Inteligência artificial. Todos os pedidos à IA passam pelo Gateway de IA do core, que os encaminha para o Serviço de IA. Este trata do contexto e do RAG sobre a legislação, remove os dados pessoais antes da inferência e regista a proveniência de cada resposta (modelo, versão do prompt, fontes e data). O resultado é sempre um rascunho, que só chega ao cliente depois de aprovado pelo consultor. No MVP, essa aprovação faz-se na validação do roadmap da Avaliação: as recomendações e explicações da IA entram no roadmap e só ficam visíveis para o cliente depois de o consultor o validar (evento RoadmapValidated). A Revisão e Aprovação, que estende esta etapa aos restantes documentos, fica para depois do MVP.
Isolamento e auditoria. Cada pedido passa pelo controlo de acessos (RBAC) e pelo contexto do tenant, e cada escrita fica no registo de auditoria, que só aceita novas entradas, na mesma transação. O Responsável designado e o Analista só acedem à sua organização, e o Consultor só às que lhe estão atribuídas.



4.5 Fluxo de um pedido à IA

Entrada e autorização (1 a 3). O pedido sai da interface por HTTPS e chega ao Nginx, que o encaminha para o BFF. O BFF, que autenticou o utilizador no Keycloak com OIDC e MFA, envia o pedido ao core juntamente com o token de acesso. No core, o Controlo de Acessos valida o token e verifica se o papel do utilizador pode usar aquele endpoint, e o Contexto do Tenant associa o pedido a uma única organização. Só depois o pedido chega ao plugin de funcionalidade que precisa da IA, como a Avaliação, as Políticas ou os Incidentes.

Preparação do contexto (4 e 5). Nenhum plugin contacta diretamente o Serviço de IA: todos os pedidos passam pelo Gateway de IA. O Construtor de Contexto reúne apenas os dados desse tenant que o pedido pode usar, incluindo o estado dos controlos, que lê do Motor de Conformidade em modo só de leitura. Assim, a IA trabalha sobre um estado calculado de forma determinística e nunca o altera. Antes de sair do core, o contexto passa pela Redação, que remove os dados pessoais e eventuais segredos (RNF13).

Geração do rascunho (6 e 7). O Serviço de IA (FastAPI) recebe o pedido já anonimizado. Faz uma pesquisa RAG na Base de Conhecimento, que reúne a legislação, os controlos e os documentos do CNCS e à qual acede apenas em leitura, e constrói o prompt. O modelo de linguagem gera o rascunho a partir desse prompt. O fornecedor do modelo fica abstraído pelo Serviço de IA: recebe apenas o prompt anonimizado e, se precisar de chave de acesso, esta é

lida do cofre de segredos. O Serviço de IA não tem acesso de escrita a nenhum dado da plataforma (RNF11).

Verificação e proveniência (8). O rascunho regressa ao Gateway de IA com as fontes utilizadas. As Verificações de Saída confirmam o formato e as fontes citadas e identificam o conteúdo como gerado por IA, cumprindo a obrigação de transparência do AI Act. A proveniência de cada resposta (modelo, versão do prompt, fontes e data) fica registada no Audit Trail (RNF14).

Aprovação humana (9). No MVP, o rascunho entra no roadmap da Avaliação, onde o consultor o revê, edita e valida (RoadmapValidated). Depois do MVP, os restantes documentos gerados pela IA, como políticas e notificações de incidente, seguem para a Revisão e Aprovação, onde o consultor os revê, edita e aprova. Só depois desta aprovação, também registada no Audit Trail, o documento fica visível para o cliente (RNF12). As respostas meramente informativas do assistente dispensam esta etapa, mas continuam identificadas como geradas por IA.

Ficheiros carregados (pós-MVP). Quando o pedido envolve documentos do cliente, o core guarda-os no armazenamento de objetos e cria uma tarefa para a Sandbox de Documentos. A sandbox lê o ficheiro, extrai o texto sem acesso à rede e aceitando apenas tipos de ficheiro autorizados, e devolve-o marcado como não fidedigno, para que o seu conteúdo nunca seja interpretado pelo modelo como instruções (RNF10).

Dados. Todas as consultas do core ao PostgreSQL são filtradas pelo tenant, as tarefas assíncronas passam pelo Redis e os ficheiros ficam no armazenamento de objetos, tal como descrito na vista de implantação.

